Fundamentals of Infrastructure Security

Francisco Acosta

Final Project | October 2024

Introduction

This project delves into the core principles of infrastructure security, covering critical areas such as identifying security vulnerabilities, conducting risk assessments, and implementing intrusion detection and prevention systems using Snort.

It also includes network analysis through Wireshark, the implementation of firewall rules, securing network communications using OpenSSL, and performing live memory analysis for enhanced system protection.

Intrusion Analysis

Intrusion Analysis

This section of the project focused on intrusion analysis and data extraction techniques.

It includes an examination of common network attacks, along with the implementation of basic analytical methods to detect and mitigate attacks within a Linux environment.

Wireshark serves as the primary tool for capturing and analyzing network traffic, enabling the extraction of relevant data.

The analysis covers captured packets, with particular attention to ICMP, TCP, and HTTP traffic.

Basic Attack Analysis

1. Packets 20 and 22 captured ICMP traffic with subtle differences between them.
   Compare the time-to-live and data field sizes in the two packets. What differences do you see?
   Packet 20 has a time-to-live value of 64 and a data field size of 98 bytes.
   Packet 22 has a higher time-to-live value of 128 and a smaller data field size of 74 bytes.

2. What operating system generated the echo request in packet 20?
   The time-to-live value differentiates what operating system is utilized. The Linux/Unix operating system generated the echo request for packet 20 because the time-to-live value is 64. Additionally, the Windows operating system generated packet 22 because the time-to-live value of is 128.

3. What took place at packet number 37 and beyond?
   The OWASP-BWA machine is terminating connections while the Ubuntu machine continues to attempt communication. The Ubuntu machine is still able to receive packets during this process, as indicated by a pattern of receiving an RST flag followed by an ACK flag.

4. What is suspicious about the flag settings in packet 22846?
   The FIN flag is notated, which means the session between both machines has been terminated.

5. What is the IP address of the host being targeted? 192.168.25.1

OpenSSL

Open SSL

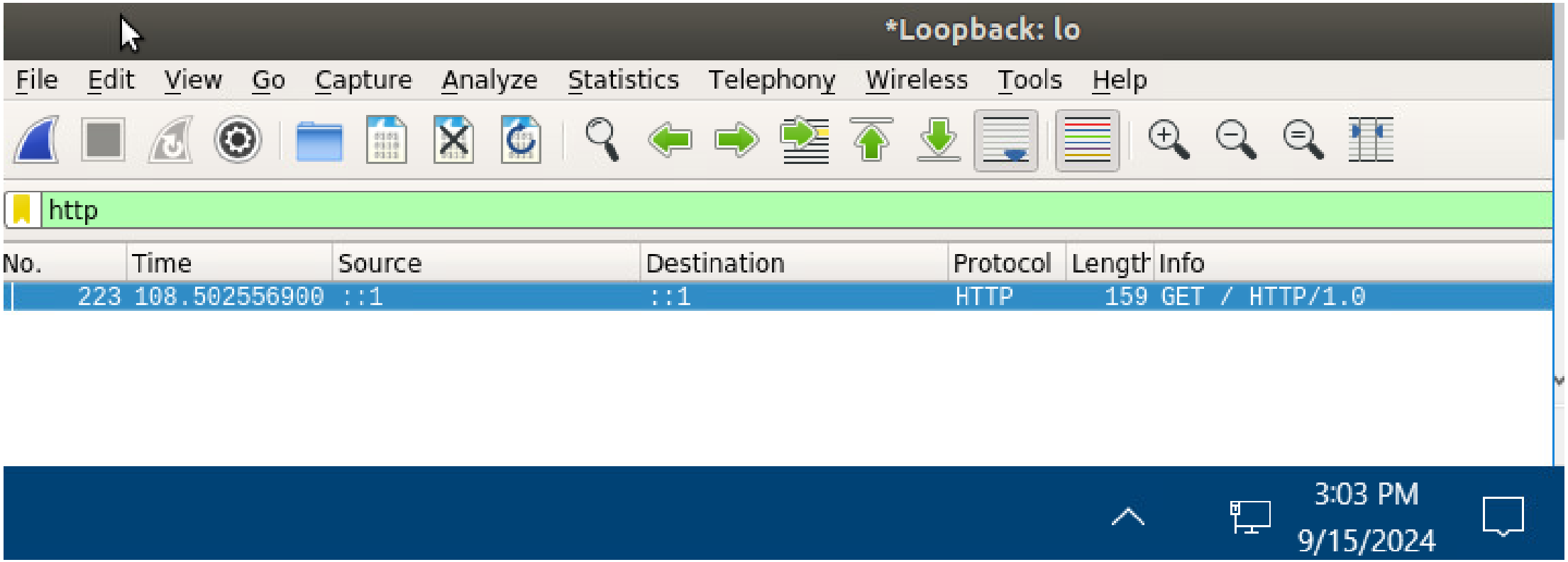
This section of the project focuses on conducting a manual OpenSSL analysis in a Linux environment.

The process began with the creation of an SSL/TLS file that is secured using public and private key encryption.

After the file was encrypted, it was tested to ensure functionality.
It was then successfully decrypted to verify the integrity of the process.

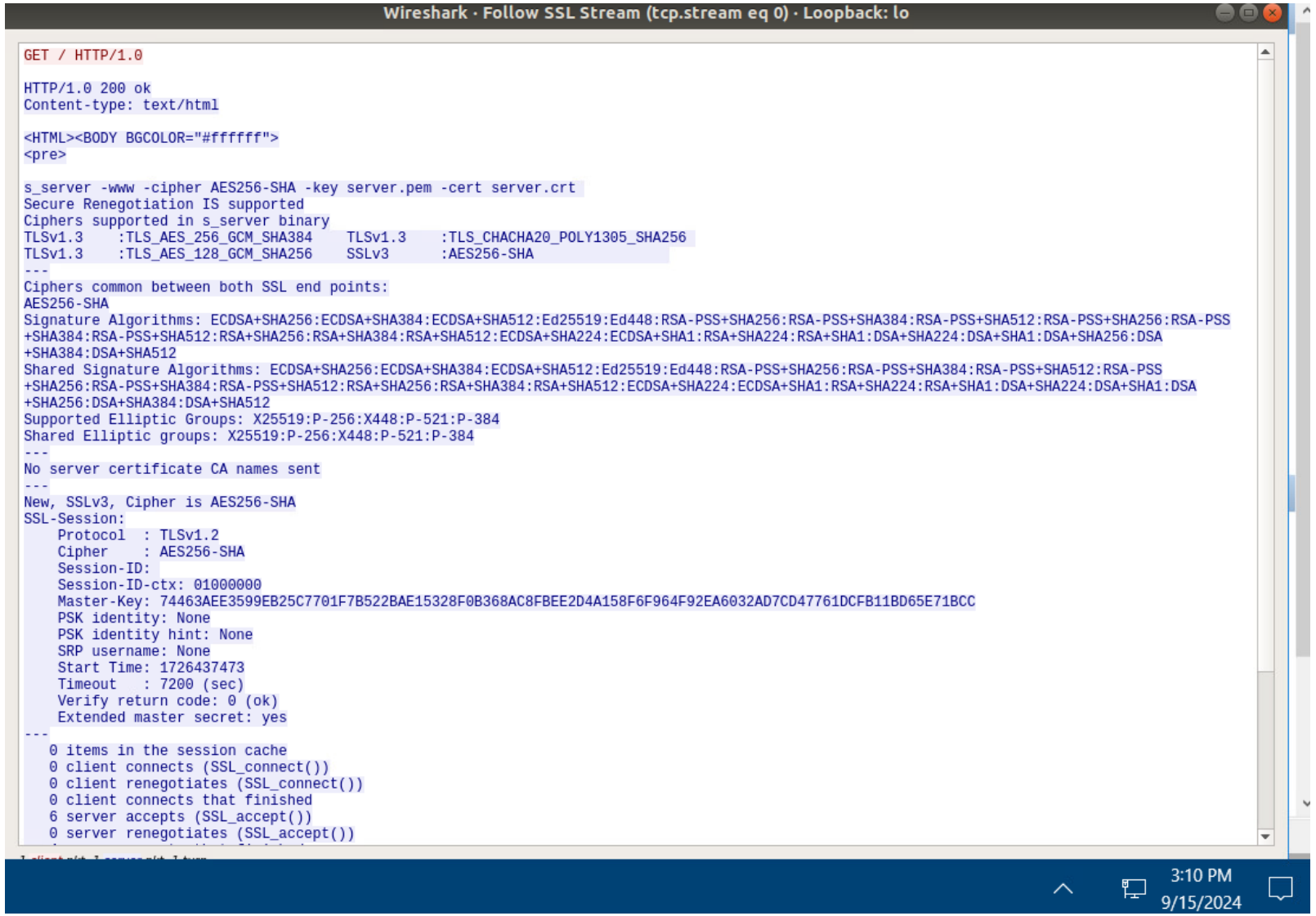
SSL/TLS File

The file does not contain any readable information



Properly Encrypted SSL/TLS File

The file was successfully encrypted



Snort

Snort

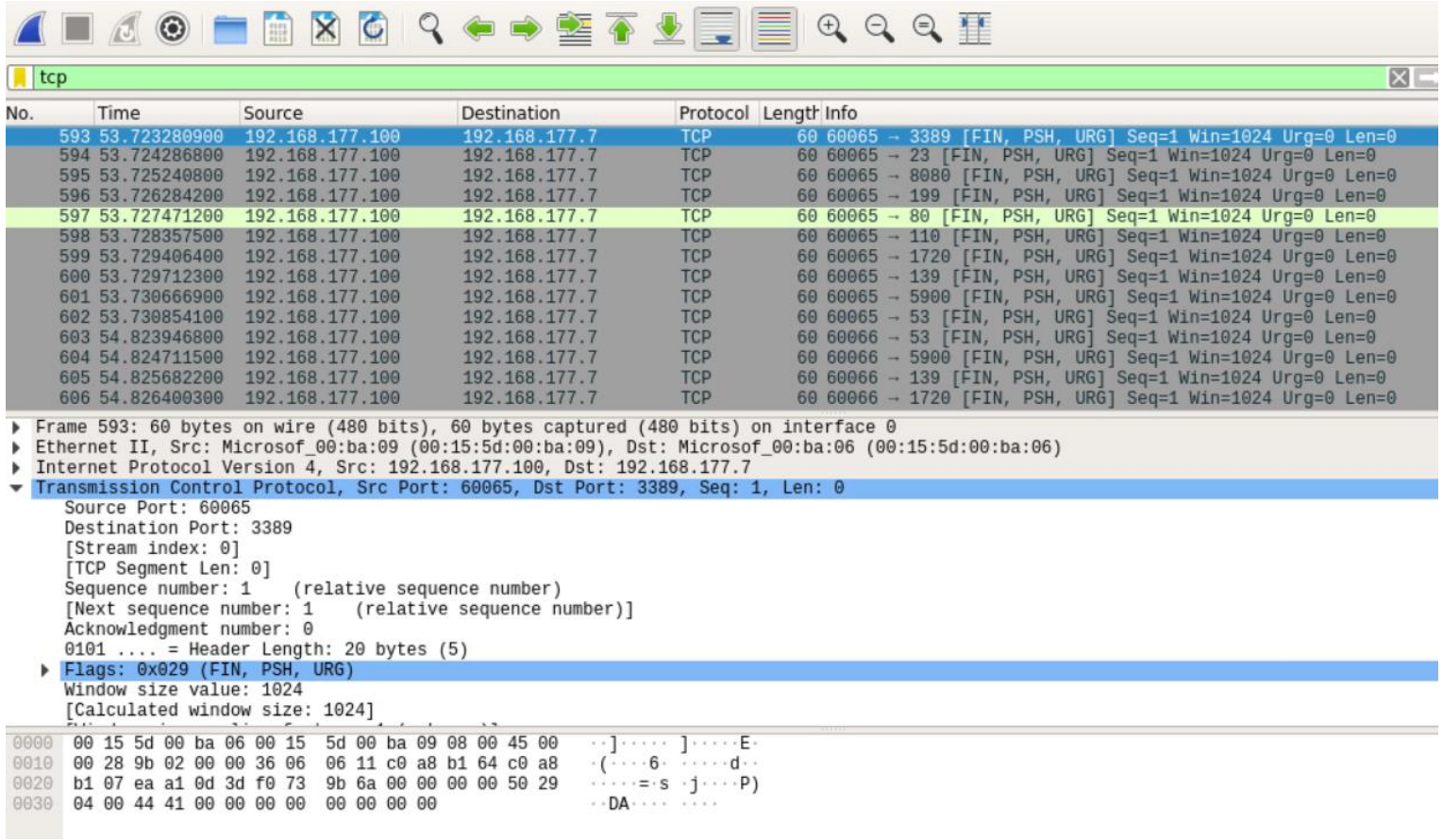
The capabilities of intrusion prevention systems (IPS) were investigated using Snort, an open-source IPS software.

Custom rules were developed to detect malicious network activity, triggering alerts whenever network packets matched specified criteria.

These alerts provide administrators with real-time notifications of potential threats.

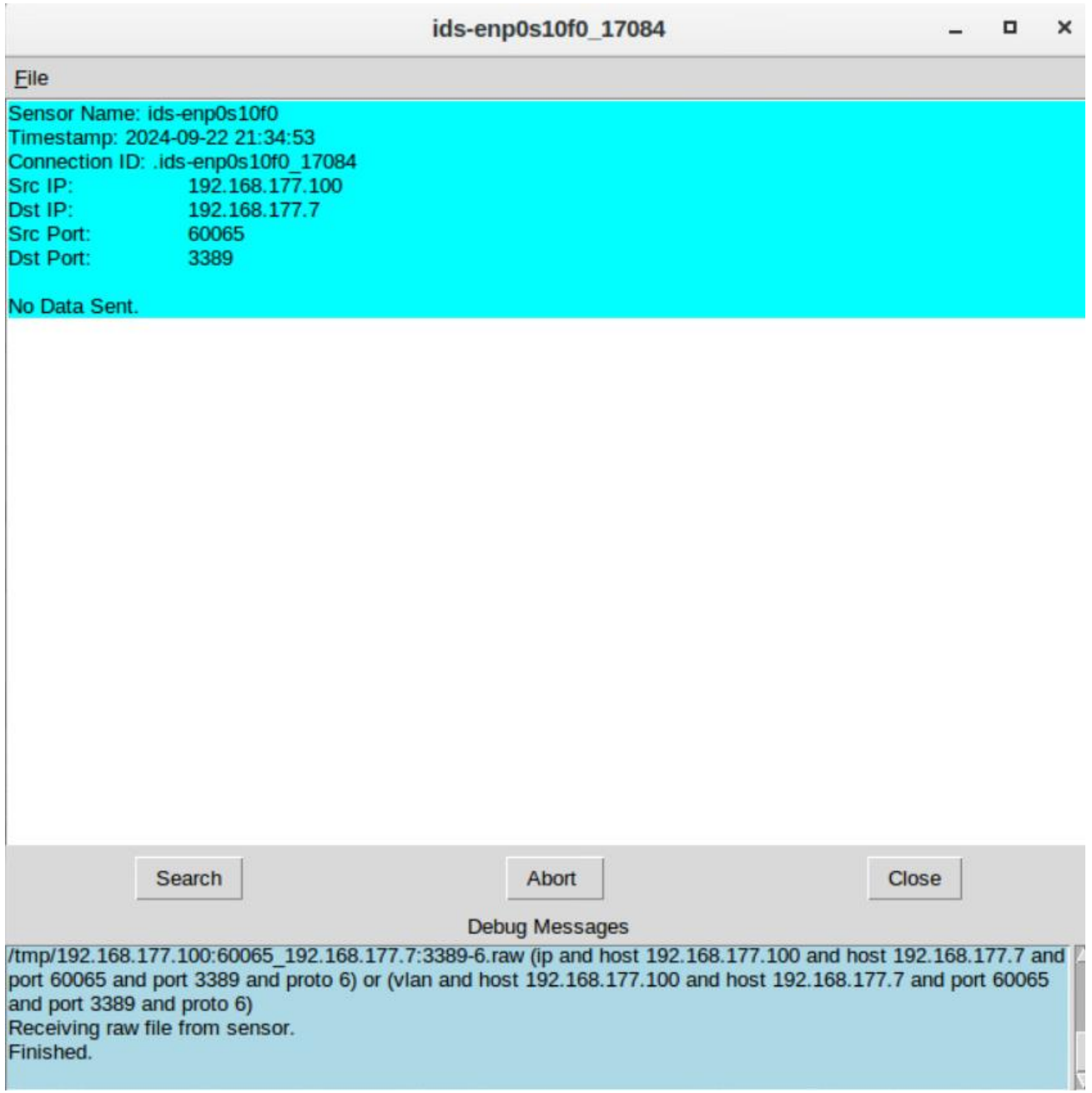
Network Activity

Potentially Malicious Behavior Detected



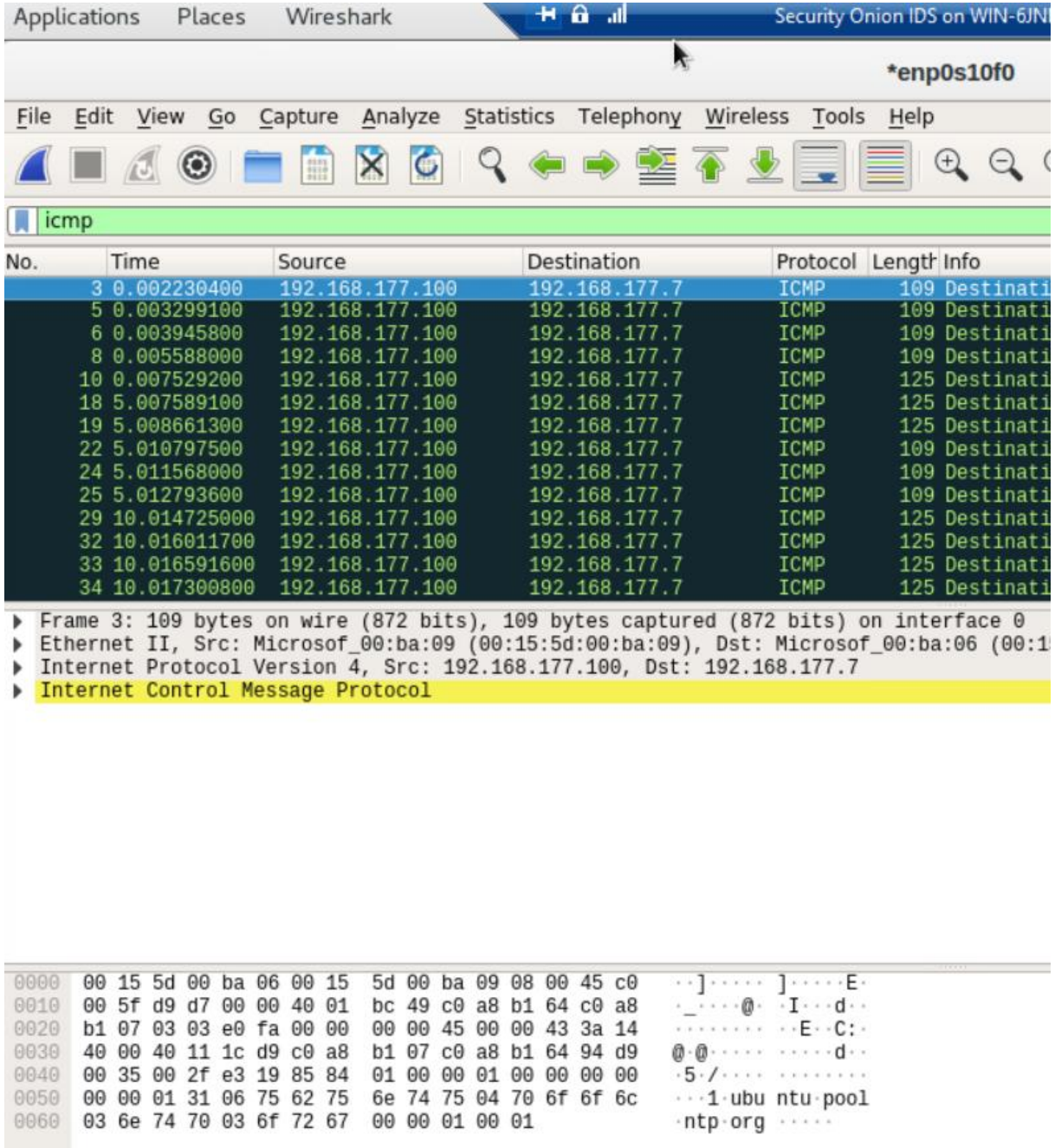
Snort Rules

Alert Details



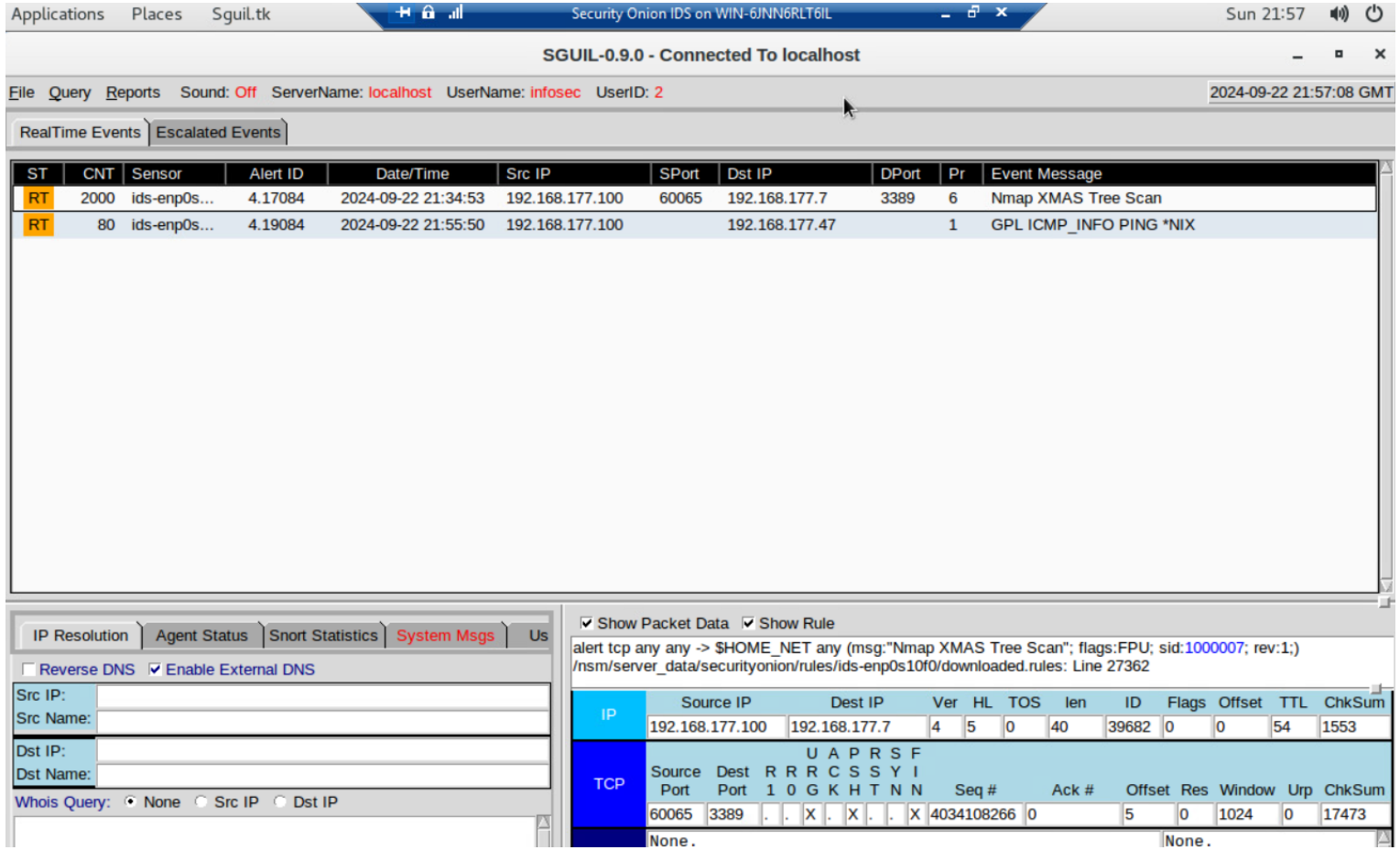
Network Activity

ICMP Packets of an External Machine Sending Echo Requests



Snort Rules

Defined Rules Create An Alert



Live Memory Analysis

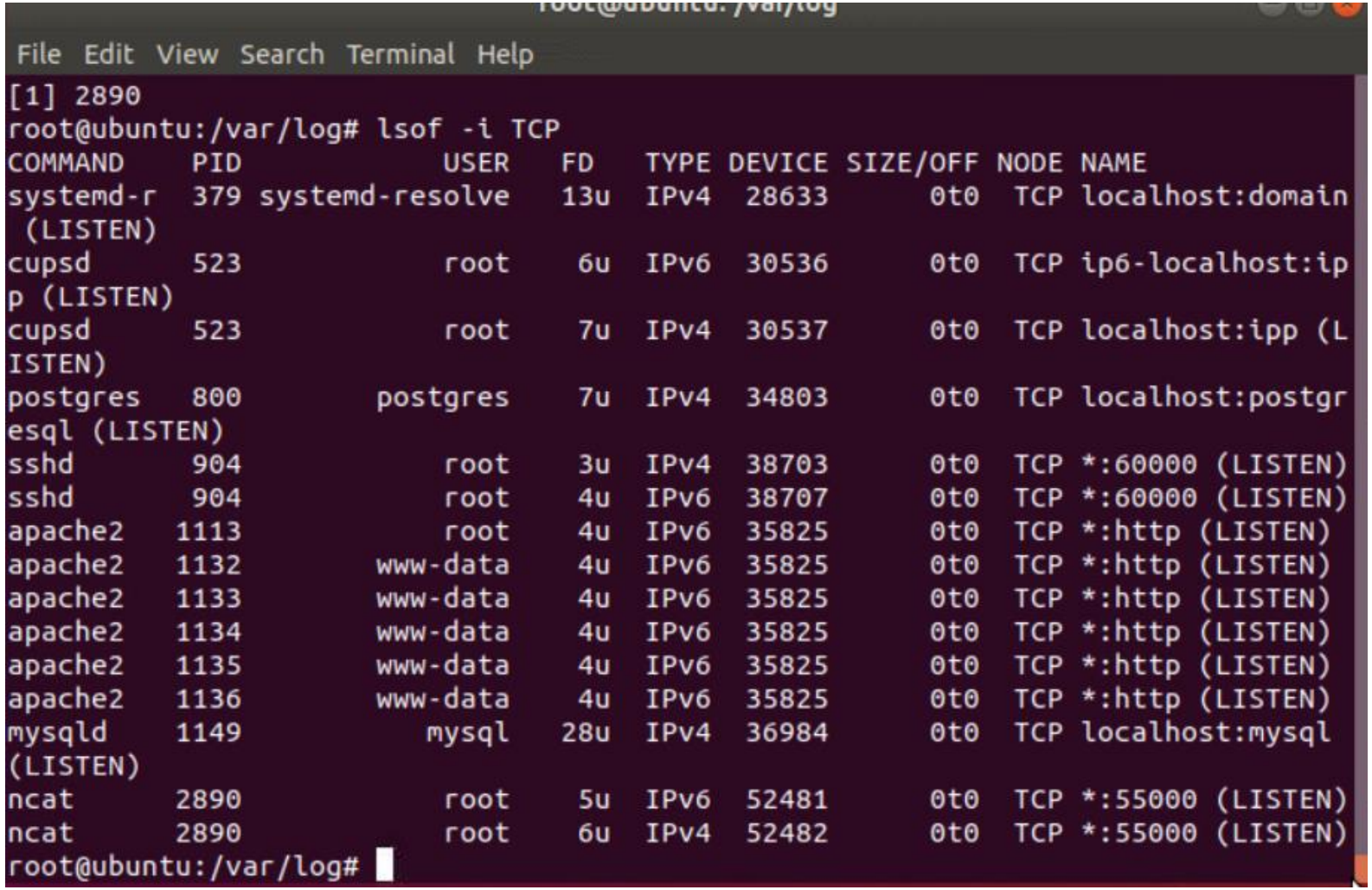
Live Memory Analysis

This section analyzed both Linux and Windows environments.

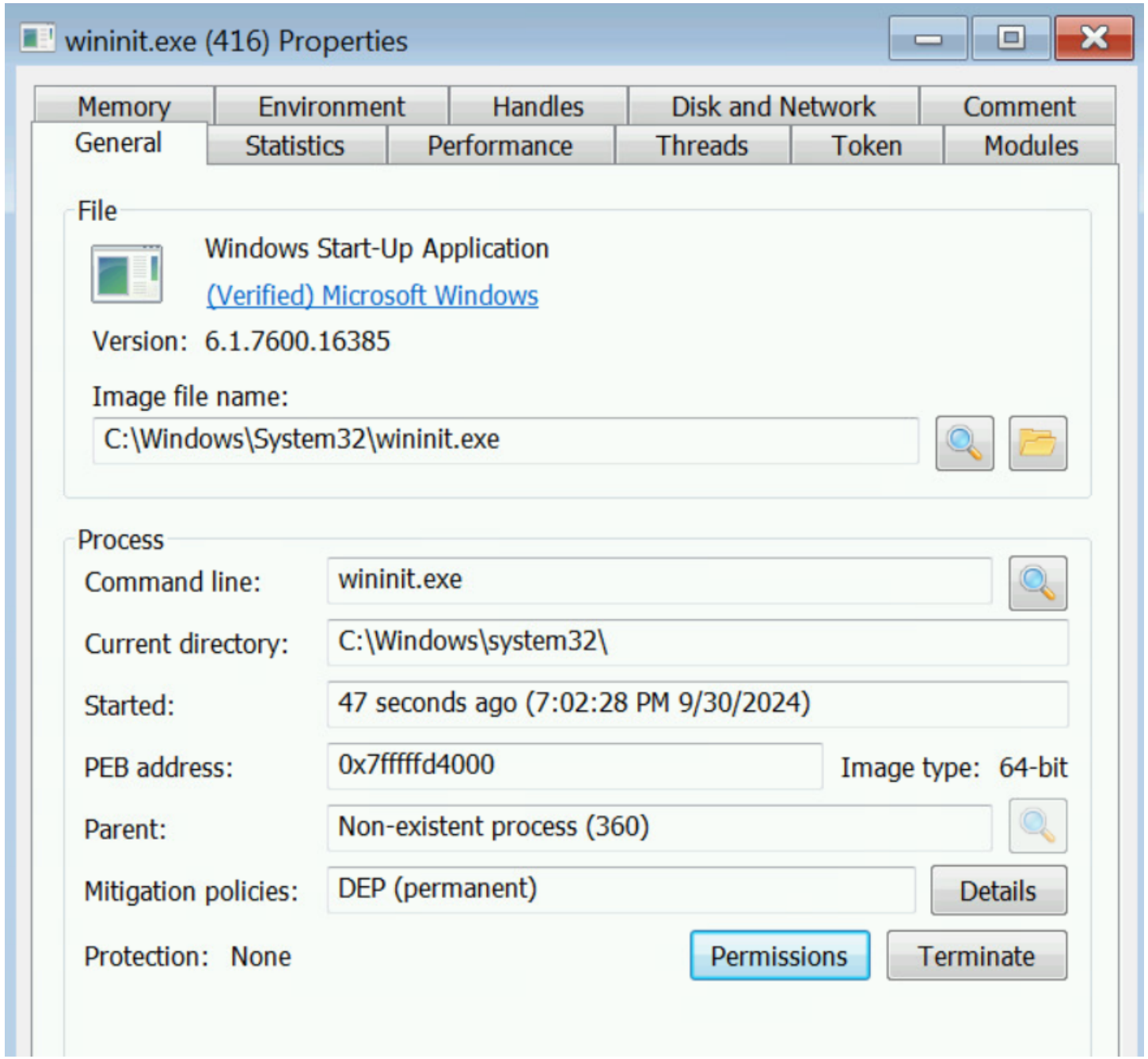
In the Linux environment, a system snapshot was created by performing a memory analysis of running processes.

On the Windows side, tools like Process Hacker and Process Monitor were employed to troubleshoot locating registry information related to an application.

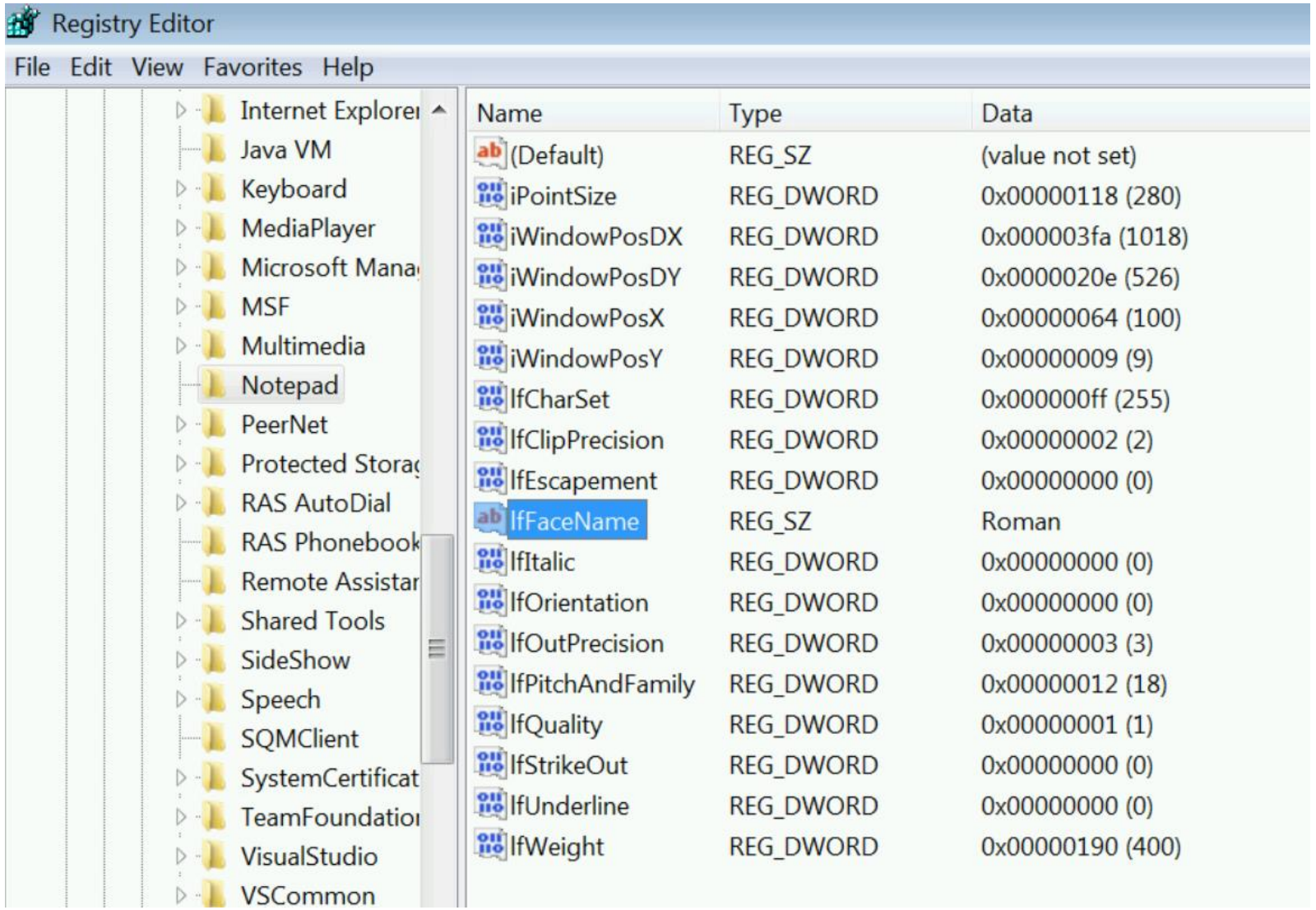
Linux Processes



Process Hacker



Process Monitor



Firewall

Firewall

This part of the project focused on configuring rules to manage time-based access to a virtual machine.

Specifically, the firewall’s iptables policy on the Linux system was modified to restrict or allow access during predefined time periods each week.

Time-Based Access

Route Added to the Firewall Machine

```
root@owaspbwa:~# netstat -rn
Kernel IP routing table
Destination     Gateway         Genmask         Flags   MSS Window  irtt Iface
192.168.177.0   172.16.0.10     255.255.255.0   UG        0 0          0 eth0
172.16.0.0      0.0.0.0         255.255.255.0   U         0 0          0 eth0
root@owaspbwa:~#
```

Time-Based Access

Route to Firewall Machine Successful

```
student@ubuntu:~$ ping -c 3 172.16.0.50
PING 172.16.0.50 (172.16.0.50) 56(84) bytes of data.
64 bytes from 172.16.0.50: icmp_seq=1 ttl=63 time=5.75 ms
64 bytes from 172.16.0.50: icmp_seq=2 ttl=63 time=5.22 ms
64 bytes from 172.16.0.50: icmp_seq=3 ttl=63 time=4.50 ms

--- 172.16.0.50 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2003ms
rtt min/avg/max/mdev = 4.501/5.162/5.759/0.518 ms
```

Time-Based Access

Successful Login During Defined Timeframe

```
student@ubuntu:~$ ssh root@172.16.0.50
root@172.16.0.50's password:
You have new mail.
Last login: Mon Oct  7 13:00:59 2024 from 192.168.177.100

Welcome to the OWASP Broken Web Apps VM

!!! This VM has many serious security issues. We strongly recommend that you run
    it only on the "host only" or "NAT" network in the VM settings !!!

You can access the web apps at http://172.16.0.50/

You can administer / configure this machine through the console here, by SSHing
to 172.16.0.50, via Samba at \\172.16.0.50\, or via phpmyadmin at
http://172.16.0.50/phpmyadmin.

In all these cases, you can use username "root" and password "owaspbwa".

root@owaspbwa:~#
```

Challenges

Challenges Encountered During This Project

- Learning unfamiliar software tools like Snort and Wireshark.
- Developing a solid understanding of network security to design effective prevention measures.
- Mastering network terminology to navigate and work within security architecture.
- Gaining knowledge of various technologies involved in infrastructure security.

Career Skills

Career Skills Gained

- Network Analytics: Proficient in using techniques to secure networks by capturing and analyzing network traffic with Wireshark.
- Encryption: Skilled in creating secure SSL/TLS certificates using public and private key encryption.
- Intrusion Detection: Experienced with Snort Intrusion Detection System, including the ability to write custom rules to detect and alert administrators of malicious network activities.
- Live Memory Analysis: Capable of performing live memory analysis to identify potential threats in real-time.
- Firewall Configuration: Able to configure firewalls to enforce time-based access controls on virtual machines.

Conclusion

Conclusion

This project explored infrastructure security, focusing on identifying vulnerabilities, conducting risk assessments, and implementing Snort for intrusion detection and prevention.

It also included network analysis with Wireshark, defining firewall rules, securing communications using OpenSSL, and performing live memory analysis.

Challenges involved learning unfamiliar tools and grasping key network security concepts and terminology.

Career skills gained included network traffic analysis, SSL/TLS encryption, Snort alert creation, and firewall configurations.

References

References

2024, June 20. Process Monitor v4.01. Microsoft. https://learn.microsoft.com/en-us/sysinternals/downloads/procmon

2017, April 26. Cridex malware. Computer Hope. https://www.computerhope.com/jargon/c/cridex-malware.htm Palani, Senthilkumar.

2024, March 27. How To Identify Operating System Using TTL Value And Ping Command. Opensource Technology Nix. https://ostechnix.com/identify-operating-system-ttl-ping/

Pradeep, Vijay. 2022, December 5. All About Wireshark (Part-4). Medium. https://medium.com/@vijaypradeep/all-about-wireshark-part-4-44ddfab4c190#:~:text=TCP%20flags%20are%20used%20within,a%20particular%20connection%20is%20handled.

References

McKay, Dave. 2023, December 4. How to Use the Linux lsof Command. How To Geek. https://www.howtogeek.com/426031/how-to-use-the-linux-lsof-command/

2024, July 12. How to use SSH to connect to a remote server in Linux | ssh Command. GeeksforGeeks. https://www.geeksforgeeks.org/ssh-command-in-linux-with-examples/

2024, January 30. How to check the routing table in Linux | route Command. GeeksforGeeks. https://www.geeksforgeeks.org/route-command-in-linux-with-examples/

2024, July 17. Netstat command in Linux. GeeksforGeeks. https://www.geeksforgeeks.org/netstat-command-linux/

References

OpenSSL Commands. OpenSSL.
https://docs.openssl.org/master/man1/

Advanced Encryption Standard (AES). TechTarget.
https://www.techtarget.com/searchsecurity/definition/Advanced-Encryption-Standard#:~:text=The%20Advanced%20Encryption%20Standard%20(AES)%20is%20a%20symmetric%20block%20cipher,cybersecurity%20and%20electronic%20data%20protection.

Following Protocol Streams. Wireshark.
https://www.wireshark.org/docs/wsug_html_chunked/ChAdvFollowStreamSection.html